AI policy and audit specification review

Review conclusion: The current policy direction is strong and appropriately restrictive, but it remains a design-stage draft. The policy and related test artifacts provide useful controls; they do not establish deployed enforcement, independent audit results, provider-contract compliance, or operational effectiveness.

What is already well specified

Area	Existing position	Review assessment
Authority	AI can explain an official rule but cannot become the official rule	Correct baseline; retain as a non-negotiable boundary
Data scope	Student records are prohibited from provider transmission; course/institution policy scopes use	Strong stated rule; verify classification, retrieval, attachment and tool-output enforcement end to end
User transparency	AI-assisted label, allowed data scope, sources, confidence/limits, policy, cost and action preview	Good interface standard; define audit evidence that checks every required response field
Academic integrity	Course AI policy can restrict use; disallowed actions are disabled with explanation	Good; resolve institution/course/assessment conflict precedence and accommodation/non-AI alternatives
Actions	Writes, sends, shares, pays and registers require preview	Require binding approval receipt, expiry, exact target/content, idempotency and reconciliation
Evaluation	Red-team, citation sample, refusal review and bias review described	Valuable; threshold, sampling, reviewer independence, datasets and failure disposition need operational specification
Incident response	Suspected record leakage triggers tenant AI shutdown and escalation	Correct; connect to incident severity matrix, legal/contract notification workflow and re-enable conditions

Material gaps to close before an audit-ready policy

1. **Policy hierarchy and conflict resolution:** Define exact precedence among law/contract, institution, program, course, assessment, user preference, and provider/model restrictions. The most restrictive compatible rule should win; conflicts must return a reasoned denial rather than a silently widened route.
2. **Data classification decision evidence:** The policy says content scans block certain patterns, but auditability needs a recorded decision for prompts, attachments, retrieval chunks, tool outputs, redactions and mixed content—without retaining raw sensitive prompts by default.
3. **Provider evidence and contractual controls:** “No training,” “no retention beyond request,” and US processing are provider- and contract-specific assertions. Maintain signed terms, region/configuration evidence, model version, subprocessor status, approval expiry, and change detection; do not make universal claims.

4. **Retrieval and tool boundary:** Test prompt injection, hidden instructions, malicious source documents, cross-tenant retrieval, tool output injection, excessive agents/retries, and unsafe redirects. Retrieval authority must not become tool authority.
5. **Evaluation design:** The stated "100% blocked" red-team pass criterion is appropriate for critical known cases, but define corpus versions, synthetic canaries, run environment, scoring, human adjudication, stochastic repetitions, severity, regression baselines and release-blocking behavior.
6. **Citation and confidence audit:** A citation supporting a statement is not the same as a complete or current answer. Sample for entailment, source authority, freshness, missing critical caveats, and presentation/accessibility. Do not present model-generated confidence as calibrated certainty without validation.
7. **Fairness and student impact:** Do not use protected characteristics or prohibited sensitive data. Define permitted segmentation, minimum cohort protections, error/appeal routes, disparate-impact investigation triggers and student-visible explanation for recommendation systems.
8. **Audit-log design:** Define immutable/signed or tamper-evident event history for request metadata, policy/configuration versions, classification, route, source identifiers, tool permission, action preview/approval/execution receipt, outcome and incident linkage. Limit log data to avoid creating a shadow student record or retaining raw sensitive content.
9. **Human escalation and correction:** Define service ownership, response expectations only after approval, student correction path, institution notification criteria and non-AI path for blocked/equity-sensitive situations.
10. **Re-enable process:** After a policy violation or provider incident, require containment, impact assessment, remediation, red-team/evaluation replay, contract/config review and named approval before reactivation.

Audit evidence specification

Evidence family	Minimum proof	Review cadence
Governance	Approved policy version, owners, use-case register, risk decisions, training	At least at each material change and scheduled policy review
Routing	Versioned gateway rules; deny/allow tests; data-minimization/route decision records	Every gateway, model, provider, tool or policy change
Providers	Approved registry, terms/DPA, region/retention/training evidence, reviews, expiry	Onboarding, renewal, material change
Course policy	Effective policy precedence, published student/instructor UI, enforcement tests	Term/assessment changes and release tests
Evaluation/red team	Versioned corpus, results, human review, severity/disposition, regression comparison	Before activation and after material change; scheduled monitoring
Transparency	Captured UI evidence and accessibility checks for labels, sources, limits, action confirmations	Each UX/release change
Actions	Exact previews, bound approvals, execution receipts, idempotency/reconciliation tests	Every high-impact action release

Evidence family	Minimum proof	Review cadence
Incidents	Exercise records, incident timeline, decision log, remediation and re-enable evidence	Tabletop schedule and each incident

Proposed audit assertions

1. A request cannot reach an external provider when its effective classification or policy forbids transmission.
2. A response displayed as AI-assisted contains the required scope, policy, source/limit and escalation information, subject to an accessible presentation test.
3. An AI workflow cannot execute a consequential action without a bound human confirmation and authoritative receipt/reconciliation where applicable.
4. A model/provider/policy/tool change triggers a recorded evaluation and applicable red-team tests before expanded activation.
5. Audit records allow a reviewer to reconstruct the policy and configuration—not sensitive raw content—that governed a sampled request.
6. An incident disables the affected route at an appropriate tenant/scope and cannot be closed or re-enabled without replayed evidence.

Current evidence boundary

The available repository excerpts describe a draft policy and a unit-level red-team suite. The red-team file explicitly labels itself unit-level and says no provider call is needed. Therefore it evidences intended test cases, not successful provider-side leakage prevention or a completed launch gate. [file:94][file:95]